

Ürün Spesifikasyon Belgesi (PRD) - BGC Assist Backend & Admin Paneli

****Proje:**** BGC Assist Yönetim Paneli

****Erişim Noktası:**** `bgcassist.com.tr/admin`

****Kapsam:**** Operasyon yönetimi, çağrı merkezi ekranları ve sistem konfigürasyonu.

****Dikkat:**** Bu belge sadece ****İç Yönetim (Internal Admin)**** panelini kapsar. Ön yüzde bulunan "Bayi Girişi" (B2B Portal) bu kapsamın dışındadır ve yetkilendirmesi ayrıdır.

1. Sistem Mimarisi ve Güvenlik Standartları

Backend sistemi, RESTful API standartlarına uygun olarak, JSON formatında veri alışverişi yapmalı ve aşağıdaki global güvenlik protokollerini uygulamalıdır.

1.1. Kimlik Doğrulama (Authentication)

* ****Giriş Endpoint'i:**** `POST /api/auth/admin-login`

* ****Mekanizma:**** JWT (JSON Web Token) tabanlı oturum yönetimi.

* ****Kısıtlama:**** Bu panelden sadece `@bgcassist.com.tr` veya yetkilendirilmiş admin domain uzantılı e-postalar/kullanıcılar giriş yapabilir.

* ****Önemli Test Kuralı:**** "Bayi" (Dealer) rolüne sahip bir kullanıcının bilgileri ile `/admin` panelinden giriş yapılamamalıdır (HTTP 403 Forbidden dönmelidir).

1.2. Rol Tabanlı Yetkilendirme (RBAC)

Sistemde aşağıdaki hiyerarşik roller bulunmalıdır:

* ****Super Admin:**** Tüm sistemi, kullanıcıları ve ayarları yönetir.

* ****Operasyon Uzmanı:**** Gelen asistans taleplerini görüntüler, çekici atar, dosya kapatır. (Silemez, sadece düzenler).

* ****Viewer (İzleyici):**** Sadece raporları ve aktif dosyaları görüntüler, değişiklik yapamaz.

2. Temel Fonksiyonlar ve API Gereksinimleri

2.1. Asistans Talep Yönetimi (Request Handling)

Frontend'den gelen "Yolda Kaldım" taleplerinin düştüğü merkezdir.

* ****Listeleme:**** Gelen talepler "Bekliyor", "İşlemde", "Tamamlandı", "İptal" statülerine göre filtrelenebilmelidir.

* ****Atama (Dispatch):**** Operatör, gelen bir talebe (Ticket) bir tedarikçi (Örn: Çekici Firması) atayabilmelidir.

* ****Validasyon:**** Statüsü "Tamamlandı" olan bir dosya, "Bekliyor" statüsüne geri döndürülemez (State Machine Validation).

2.2. Tedarikçi ve Envanter Yönetimi

* ****CRUD İşlemleri:**** Yönetici yeni çekici firması veya hizmet sağlayıcı ekleyebilmeli, iletişim bilgilerini güncelleyebilmelidir.

* ****Coğrafi Kısıt:**** Tedarikçilere "Hizmet Bölgesi" (Örn: Ankara - Çankaya) tanımlanabilmelidir.

2.3. Poliçe/Müşteri Sorgulama (Backend Search)

- * **Sorgu:** Plaka veya TCKN ile veritabanında "Elasticsearch" veya benzeri hızlı bir arama yapılabilmelidir.
- * **Gizlilik (PII):** Müşteri verileri API yanıtında maskelenerek (Örn: `532 \*\*\*\* 89`) gösterilmemeli, tam yetkili admin detay butonuna bastığında loglanarak açılmalıdır.

3. Loglama ve Denetim (Audit Logs)

Global sigortacılık ve asistans standartları gereği her işlem kayıt altına alınmalıdır.

- * **Zorunlu Alanlar:** `User\_ID`, `Timestamp`, `Action` (Update, Delete, View), `IP\_Address`, `Old\_Value`, `New\_Value`.
- * **Senaryo:** Bir operatör, müşterinin dosya statüsünü değiştirdiğinde bu işlem "İşlem Geçmişi" tablosuna salt okunur (read-only) olarak yazılmalıdır.

4. Hata Yönetimi ve Yanıt Kodları (Global Standartlar)

API, aşağıdaki standart HTTP durum kodlarını döndürmelidir:

- * `200 OK`: İşlem başarılı.
- * `201 Created`: Yeni kayıt (yeni talep, yeni kullanıcı) başarıyla oluşturuldu.
- * `400 Bad Request`: Eksik veya hatalı veri formatı.
- * `401 Unauthorized`: Token yok veya süresi dolmuş.
- * `403 Forbidden`: Admin paneline girmeye yetkisi olmayan kullanıcı (Örn: Bayi kullanıcısı denemesi).
- * `429 Too Many Requests`: Rate limiting (Aşırı istek engelleme).
- * `500 Internal Server Error`: Sunucu hatası (Loglanmalı).

5. Performans Kriterleri

- * **Sorgu Hızı:** Talep listeleme ekranı (`GET /api/requests`), 10.000 kayıtlık veritabanında dahi 500ms altında yanıt vermelidir (Pagination kullanılmalıdır).
- * **Data Integrity:** Aynı anda iki operatör aynı dosyayı düzenlemeye çalışırsa (Concurrency), ikinci işlem yapan kişiye "Bu dosya şu an başkası tarafından düzenleniyor" uyarısı verilmelidir (Optimistic Locking).